

LockonDocs Build State

This file is additive. Never remove entries. Append new state after each significant build step. Developer will be prompted to update every 5 builds.

Build Counter: 3

Current Phase: Phase 1 - Proof of Concept

Current Status: Phase 1 POC app built - scanner, folders, documents, auth, storage

Build Log

2026-07-18 | Build 0 | Project Initialisation

- Project initialised. Documentation structure created. Awaiting Phase 1 build start.
- Files created:
 - CUSTOM_INSTRUCTIONS.md - Project rules and reference
 - build_state.md - This file
 - scanner.md - Scanner feature doc
 - files.md - Folder/file management feature doc
 - admin.md - Admin/settings feature doc
- Next step: Begin Phase 1 development (scanner feature)

2026-07-18 | Build 1 | Phase 1 POC Application Built

- App scaffolded at /home/ubuntu/lockon_docs_app (NextJS, PostgreSQL, S3 cloud storage).
- Authentication: email/password (register + login), session-guarded routes, strict per-user data isolation.
- Default folders auto-provisioned per new user: Personal, School, Medical, Work, Other.
- Document Scanner (/scan): browser-native getUserMedia camera, document framing guide, live brightness/contrast enhancement, file-upload fallback for non-camera environments.
- Folder management: create custom folders with icon selection, document counts, folder view.
- Document viewer: view, rename, download, delete; files stored privately in S3 with time-limited signed URLs.
- Settings screen: profile, storage stats, sign out.

- Iframe-ready: middleware.ts sets content-security-policy: frame-ancestors * so the app embeds seamlessly in the GoodBarber shell.
- Deploy target: Abacus domain for now (custom domain later).

2026-07-18 | Build 2 | Hydration Fix (Auth Forms)

- Fixed a browser-extension-triggered hydration warning on the login/register forms (password managers / autofill tools inject a <div> into the form before React hydrates).
- Root cause confirmed: VM browser DOM and server HTML matched exactly with no injected nodes, so the warning was environment-specific (viewer's browser extension), not a code defect.
- Added suppressHydrationWarning to the <form>, .space-y-2 and .relative input wrappers in login-form.tsx and register-form.tsx, and to <body> in layout.tsx.
- Verified: tsc clean, production build success, auth smoke test (signup + login + session) passing.
- Not deployed (manual deploy only per project rules).

2026-07-18 | Build 3 | Iframe Embed Fix (net::ERR_BLOCKED_BY_RESPONSE)

- Symptom: GoodBarber native preview blocked the embedded app with net::ERR_BLOCKED_BY_RESPONSE.
- Diagnosis: app already sends content-security-policy: frame-ancestors * (framing allowed), so the block was not frame-ancestors. Most likely cause is the GoodBarber shell enforcing cross-origin isolation (Cross-Origin-Embedder-Policy), which blocks any embedded document/resource that does not send a Cross-Origin-Resource-Policy header.
- Fix: middleware.ts now sets Cross-Origin-Resource-Policy: cross-origin on all responses, and the middleware matcher was broadened to also cover _next/static assets so JS/CSS/fonts are not blocked either. (next.config.js is protected and could not be edited, so headers are applied via middleware.)
- Verified locally: response headers now include both content-security-policy: frame-ancestors * and cross-origin-resource-policy: cross-origin; tsc clean; production build success; auth smoke test passing.
- IMPORTANT: requires a manual redeploy to lockondocs.abacusai.app (and the custom domain once DNS is live) for the fix to take effect in the GoodBarber app.
- Note: custom domain lockondocs.dowmandigitalservices.com did not resolve (NXDOMAIN) at time of this build - DNS/CNAME not yet propagated.

2026-07-18 | Build 4 | Native WebView COEP Fix + PWA Login-Stuck Fix

- Two symptoms addressed in this build:
 1. GoodBarber NATIVE preview (the one that gets published) still blocked with `net::ERR_BLOCKED_BY_RESPONSE` after Build 3, even though `frame-ancestors *` and `Cross-Origin-Resource-Policy: cross-origin` were confirmed live.
 2. PWA (browser + installed) showed the login success toast but stuck on the login screen instead of moving to `/home`.
- Fix 1 (native block): `middleware.ts` now also sets `Cross-Origin-Embedder-Policy: credentialless`. When the GoodBarber native shell is cross-origin isolated (parent sets `COEP: require-corp`), the embedded document must assert its OWN COEP or the webview blocks it. “credentialless” was chosen over “require-corp” so external subresources (Google fonts, S3 signed images, helper script) keep loading without each needing its own CORP header.
- Fix 2 (PWA login stuck): `login-form.tsx` and `register-form.tsx` now use a full-document navigation (`window.location.assign("/home")`) instead of the client-side `router.replace("/home")` after a successful sign-in. In a standalone PWA/webview the client router could render `/home` before the freshly set session cookie was picked up, bouncing the user back to `/login`. Full navigation guarantees the cookie is sent. Removed the now-unused `useRouter` import from both forms.
- Verified locally: `cross-origin-embedder-policy: credentialless` now present alongside the existing `CSP + CORP` headers; `tsc` clean; production build success; auth smoke test (signup + login + session) passing.
- HONEST STATUS: the COEP fix is a strong hypothesis based on how cross-origin isolation works, but the GoodBarber native WebView cannot be reproduced here. If the native block persists after redeploy, the definitive next step is reading the exact `ERR_BLOCKED_BY_RESPONSE` suffix via WebView remote debugging (`chrome://inspect` on Android) and/or checking GoodBarber’s domain allowlist settings.
- IMPORTANT: requires a MANUAL redeploy to `lockondocs.abacusai.app` for both fixes to go live (manual deploy only per project rules).

2026-07-18 | Build 5 | Diagnostic Page for GoodBarber Native WebView Block

- Context: after Build 4, the PWA login-stuck bug is FIXED (confirmed by developer), but the GoodBarber NATIVE preview still shows `net::ERR_BLOCKED_BY_RESPONSE`. Developer cannot access WebView console logs.
- Key deduction: the native block has now persisted across every security-header change (`frame-ancestors` only -> `+CORP` -> `+COEP`).

A cause that is invariant to all our header changes is very unlikely to be caused by those headers. No service worker or manifest exists in the app, so a service-worker/WebView conflict is also ruled out.

- Action: added a controlled, header-free diagnostic page at `public/gbtest.html`, and excluded it from the middleware matcher so it is served with NO CSP / CORP / COEP headers and NO redirect. This isolates whether ANY page from our domain loads in the native preview vs the block being specific to the app response.
- Verified locally: `/gbtest.html` returns 200 with no security headers; real app pages (e.g. `/login`) still carry all three headers; production build success.
- Diagnostic URLs to test in the GoodBarber native preview (results tell us where the block is):
 1. `https://lockondocs.abacusai.app/gbtest.html` (vanilla, no headers, no redirect)
 2. `https://lockondocs.abacusai.app/login` (real app page, all headers, no redirect - bypasses the `/ 307` redirect)
- IMPORTANT: requires a MANUAL redeploy to take effect (manual deploy only per project rules).

2026-07-18 | Build 6 | ROOT CAUSE FOUND + FIXED: GoodBarber Native WebView Block

- BREAKTHROUGH: bisection test in the GoodBarber native custom section confirmed the exact culprit. Test pages served with only Content-Security-Policy: frame-ancestors * (and the page carrying all three headers) were BLOCKED with `ERR_BLOCKED_BY_RESPONSE`; pages served with only CORP, only COEP, or no headers at all LOADED FINE.
- Root cause: the * wildcard in a CSP frame-ancestors directive only matches network origins (`http/https`). GoodBarber native custom sections render inside a WebView whose parent document is served from a NON-network scheme (Capacitor/Cordova style shells use `capacitor://`, `ionic://` or `file://`). `frame-ancestors *` does not match those schemes, so our own CSP was telling the WebView the parent was disallowed, and the WebView blocked the app. The CORP and COEP headers added in Builds 3 and 4 were never the cause (they were confirmed harmless / loadable).
- Fix: `middleware.ts` now sends NO frame-ancestors CSP at all, and no CORP/COEP. It only deletes X-Frame-Options defensively (in case an upstream layer adds one). With neither framing header present, embedding is unrestricted by default, which is exactly what the GoodBarber shell needs and what the header-free plain test page proved works.
- Cleanup: removed all temporary diagnostic pages (`public/gbtest*.html`).

- Verified locally: responses no longer carry a CSP header; tsc clean; production build success; auth smoke test (signup + login + session) passing.
- Note: this fix is scheme-agnostic, so it applies to both iOS (WebKit) and Android (Chromium) native shells.
- IMPORTANT: requires a MANUAL redeploy to lockondocs.abacusai.app for the fix to go live (manual deploy only per project rules).

2026-07-19 | Build 7 | White/Gold Rebrand + New Logo

- Request: change the white/blue theme to a white/gold theme, keep text black with some subtle greys mixed in, and use the supplied LockonDocs logo (gold padlock over layered documents) in place of the placeholder shield used on the homescreen and elsewhere.
- Theme (app/globals.css): replaced the blue palette with gold + grey across both :root (light) and .dark. Primary is now gold (40 63% 46%); background near-white (40 25% 99%); foreground near-black (220 18% 12%). Subtle greys added via secondary/muted/border/input (cool grey tones) so the UI is not flat white. Accent, ring, and chart-1..5 recoloured to gold/grey. Hero gradient (light and dark) retinted from blue to gold/grey.
- Contrast decision: gold with white text fails WCAG contrast, so --primary-foreground is set to a dark tone. Filled gold buttons therefore use dark (near-black) text, which is intentional and gives strong, accessible contrast. Do not switch this back to white text.
- Logo: saved the supplied transparent PNG to public/logo.png (1024x1024). It now appears on the login screen, the register screen, and as a brand row at the top of the /home dashboard, replacing the old gold shield icon boxes. It is also wired up as the favicon / apple-touch icon and the browser theme-color was updated from blue to gold in app/layout.tsx.
- The ShieldCheck icon in Settings (the “your data is encrypted” security note) was left as an icon and simply inherits the new gold accent colour.
- Verified: tsc clean; production build success (all 9 routes); auth smoke test (signup + login + session) passing. This is a visual/branding change verified by build; not browser-pixel-verified.
- IMPORTANT: requires a MANUAL redeploy to lockondocs.abacusai.app AND securevault.dowmandigitalservices.com for the rebrand to go live (manual deploy only per project rules).

2026-07-19 | Build 8 | Landing Screen + Gradient Edge Fade (Iframe UX)

- Context: developer is keeping the GoodBarber iframe approach (embed shown full screen on the app home page, one tap opens

securevault.dowmandigitalservices.com). Going straight into the login form felt like a weird UI, and the embed's gradient showed a hard seam against the white frame around the iframe edge.

- Change 1 - Landing screen: the root route / no longer redirects straight to /login. When signed out it now renders a branded welcome screen (logo, LockonDocs wordmark, tagline, three feature chips, and a primary "Access My Vault" button plus a "Create an account" link). "Access My Vault" links to /login; signed-in users are still redirected to /home. File: app/page.tsx.
- Change 2 - Gradient edge fade: .hero-gradient (light and dark, in app/globals.css) now has an explicit background-color of the page background plus a top vignette layer that fades the gold/grey tint out to the background before the edges. This makes the gradient blend smoothly into the white frame around the embed instead of showing a seam. Applies to the landing, login and register screens (all use .hero-gradient).
- Verified: tsc clean; production build success (all routes); auth smoke test passing; AND browser-verified locally - / renders the landing screen, "Access My Vault" navigates to /login, and the gradient fades to white at the edges on both screens.
- IMPORTANT: requires a MANUAL redeploy to lockondocs.abacusai.app AND securevault.dowmandigitalservices.com to go live (manual deploy only per project rules).

2026-07-19 | Build 9 | All-Edge Gradient Fade + Login-Stuck Hardening (In-App Browser)

- Two issues reported by developer while testing the iframe embed (app home shows the embed full screen, one tap opens securevault.dowmandigitalservices.com in the in-app browser):
 1. A white border around the gradient was still visible; the gradient needed to fade to white at ALL edges to mask the frame.
 2. The login screen showed the success toast but stuck on the login screen instead of moving to /home.
- Fix 1 (gradient): reworked .hero-gradient (light and dark, app/globals.css). The single centred radial vignette from Build 8 did not fully fade the left/right edges on a tall mobile viewport. Replaced it with two edge-fade linear-gradient layers stacked on top of the tint - one fading the left and right edges to the page background (0-16% / 84-100%), one fading the top and bottom edges (0-11% / 89-100%). The gold/grey tint radials were nudged toward the upper area and now show only in the central region. Result: every edge fades to white regardless of aspect ratio, so the frame around the embed is masked. Applies to the landing, login and register screens.

- Fix 2 (login stuck): login-form.tsx and register-form.tsx already used a full-document window.location.assign("/home") (Build 4). The remaining failure mode in an in-app browser / webview is a cookie-timing race: the session cookie set by signIn is not always readable when /home loads server-side, so the server redirects back to /login. Added a short poll of getSession() (up to ~3s, 200ms interval) after a successful sign-in / sign-up; navigation to /home only happens once the client confirms the session cookie is committed. Imported getSession from next-auth/react in both forms.
- Verified: tsc clean; production build success (all routes); auth smoke test passing; browser-verified locally that the landing gradient fades to white on all edges AND that login navigates cleanly to /home with the new session-poll logic.
- HONEST STATUS on Fix 2: the login flow is confirmed working in a normal browser (it worked before too). The original "stuck" report is specific to the GoodBarber in-app browser / webview, which cannot be reproduced in this environment. The getSession poll is a robust, standard hardening for the cookie-timing race and is the most likely fix, but it should be re-tested in the actual in-app browser after redeploy. If it still sticks there, the next step is to inspect cookie storage / SameSite behaviour in that specific webview.
- IMPORTANT: requires a MANUAL redeploy to lockondocs.abacusai.app AND securevault.dowmandigitalservices.com to go live (manual deploy only per project rules).

2026-07-19 | Build 10 | Landing "Access My Vault" Breaks Out of Embed (fixes login-stuck)

- Developer insight (correct root cause): the login only ever worked because the old flow opened securevault.dowmandigitalservices.com in the in-app browser (a top-level page WITH a web header). The Build 8 landing screen's "Access My Vault" was a normal in-embed navigation, so /login loaded INSIDE the GoodBarber embed (iframe / webview). In that embedded context the app is a third-party origin, so the browser blocks its session cookie (iOS Safari ITP / third-party cookie blocking) - the reason sign-in toasts, spins and then sticks on the login screen.
- Fix: added a client launcher component components/home/vault-launch.tsx and used it for both landing actions ("Access My Vault" -> /login, "Create an account" -> /register) in app/page.tsx. It renders an anchor with target="_blank" rel="noopener noreferrer" AND an onClick that: (1) opens the absolute URL in a new top-level window via window.open(url, "_blank") (in the GoodBarber shell this launches the in-app browser with its header; in a normal browser, a new tab); (2) if that is blocked, breaks out of the iframe via window.top.location; (3) last-resort same-window navigation. Either way the app now runs

first-party, so cookies + login + camera work - matching the previous working “open in browser” behaviour.

- The landing screen itself stays inside the embed on the GoodBarber home page; only the vault actions break out. Signed-in users are still redirected to /home.
- Verified: tsc clean; production build success (all routes); auth smoke passing; confirmed in the rendered landing HTML that both actions carry target=“_blank” + rel and keep the button styling. The definitive test is tapping “Access My Vault” inside the GoodBarber app after redeploy - it should open the in-app browser (with header) and login should complete without sticking.
- IMPORTANT: requires a MANUAL redeploy to lockondocs.abacusai.app AND securevault.dowmandigitalservices.com to go live (manual deploy only per project rules).

2026-08-01 | Build 11 | Phase 2 Feature Build (Folders, Search, Admin, Security, Privacy, Imaging)

- Context: customer accepted Phase 1, paid the remainder, and approved the full Phase 2 scope (GBP 2,000 / USD 2,540 at 1.27). One item was explicitly deferred by the developer: encryption at rest is NOT built in this phase and is recorded as an accepted risk in docs/production.md. Documents remain isolated per user and stored on US-based infrastructure with time-limited signed access URLs.
- Planning doc: added docs/production.md covering deployment, security posture, monitoring, backups and the accepted encryption-at-rest risk.
- Schema (additive only, pushed with prisma db push, no data loss): User gained storageLimit (default 5GB), emailVerified, failedLoginAttempts, lockedUntil. New models PasswordResetToken, EmailVerificationToken (both store a SHA-256 hash of the token, never the raw value, with expiry and usedAt), and AuditLog (userId nullable with SetNull on delete, action, detail, ip, createdAt, indexed).
- Folder management: rename now also lets the user change the folder icon from the built-in choice set (create dialog already had the picker; the same picker was added to the rename dialog). Documents can be moved between folders. Folder delete decrements the owner storage usage. Custom uploaded icons from Tracey are deferred until she supplies the graphics (noted in docs/files.md); the built-in icon set is fully working.
- Search and sorting: new /search screen and /api/search endpoint. Case-insensitive name search scoped to the signed-in user, with sort by date (newest/oldest) and name (A-Z/Z-A), optional folder scope. Reachable from a Search button on the home screen.
- Admin panel: gated by the existing isAdmin flag. /admin screen with two tabs - Users (view all users, adjust per-user storage limit, unlock a

locked account) and Activity (recent audit log with optional action filter). Non-admins are redirected away. New endpoints under /api/admin.

- Auth hardening: password policy (min 8 characters, at least one letter and one number) enforced on signup and reset and surfaced as a hint on the register form. Forgot-password flow (/forgot-password) emails a time-limited reset link (1 hour); reset page verifies the token, applies the policy and clears any logout. Email verification is sent on signup as a soft (non-blocking) 24-hour link and /verify-email confirms it. Login logout: 5 failed attempts locks the account for 15 minutes. Password reset and email verification notifications registered as critical USER emails.
- Upload safety: presigned-URL and document-create endpoints validate content type (JPEG, PNG, WebP, HEIC, HEIF, PDF), enforce a 25MB per-file cap, and check the user storage quota (HTTP 413 when exceeded). The scanner now sends fileSize so the quota check runs before upload.
- Privacy / CCPA-CPRA: "Download my data" exports a JSON file of the account, folders and documents (with time-limited signed download URLs). "Delete my account" requires password confirmation, deletes all of the user's stored files from cloud storage, writes an audit entry, then removes the account and all related records (cascade). Both are in Settings.
- Audit log: best-effort recordAudit helper writes entries for folder update/delete, document move/delete, signup, admin actions, data export and account deletion, with client IP where available. Failures never block the main request.
- Enhanced imaging: the scanner now supports rotate (90-degree steps), interactive crop (draggable rectangle with corner handles), brightness/contrast sliders, multi-page capture with a thumbnail strip, and export. A single page saves as JPEG; multiple pages (or the "Save as PDF" toggle) save as a single PDF via jsPDF (A4, one image per page). Document and folder viewers now render a PDF placeholder icon plus an open/download action for application/pdf documents instead of a broken image; download uses the correct file extension.
- Verified: tsc clean; production build success (all routes, 14 pages); automated auth smoke test passing (signup 201, login 200, session present). This is build-and-automated-test verified. Not browser-pixel-verified; the new interactive imaging (crop/rotate/sliders/multi-page) and the email flows should be exercised in a real browser and, for the reset/verify emails, an inbox after redeploy.
- IMPORTANT: requires a MANUAL redeploy to lockondocs.abacusai.app AND securevault.dowmandigitalservices.com to go live (manual deploy only per project rules).

2026-08-01 | Documentation sync (no code build)

- Brought the feature docs in line with the Build 11 Phase 2 code: scanner.md (imaging: crop/rotate/brightness-contrast/multi-page/PDF export, jsPDF, PDF handling in viewers, offline marked deferred), files.md (rename/move/delete, search and sorting, built-in folder icons, storage quota, PDF placeholders, custom icon graphics deferred), admin.md (Settings profile/storage/data-export/account-deletion, Admin panel with Users and Activity tabs, auth hardening, real account delete rather than soft delete).
- CUSTOM_INSTRUCTIONS.md updated: added production.md to the feature-doc list, marked Phase 1 and Phase 2 complete with Phase 3 next, recorded encryption at rest as a deferred accepted risk, noted offline-first is a design goal not yet built, set build counter to 11, and noted manual deploy covers both hosts.
- No application code changed in this entry, so the numbered build counter stays at 11.

2026-08-01 | Admin account provisioned (no code build)

- Added admin@lockondocs.com to scripts/seed.ts (isAdmin true) and ran the seed against the shared database. Verified: isAdmin true, not locked, not deleted, password matches, 5 default folders created.
- The database is shared across the preview and both live hosts, so the admin login works on securevault.dowmandigitalservices.com immediately with no redeploy.
- The pre-existing seeded test account was left untouched. No application code changed, so the numbered build counter stays at 11.

2026-08-01 | Build 12 | Admin Console Upgrade (Dashboard, Users, Admin Management, Audit, Backups)

- Context: developer approved a full upgrade of the admin area from the old two-tab panel to a dedicated full-screen console, with a super-admin role for admin management. No pricing change (part of ongoing Phase 2/3 work). The build deliberately does NOT add any capability for an admin to view another user's documents: per-user isolation is preserved.
- Schema (additive only, pushed with prisma db push, no data loss): User gained isSuperAdmin (Boolean, default false) and suspendedAt (DateTime, nullable). Suspension is tracked separately from the lockout fields.
- Role model: two levels, Admin (isAdmin) and Super Admin (isSuperAdmin). admin@lockondocs.com is seeded as the super admin (LockDocsAdmin26!, unchanged); john@doe.com remains a plain admin. lib/admin.ts resolves the caller's role from the database on every request via getAdminUser/getSuperAdminUser; getSessionUser and the next-auth session type now expose isAdmin/isSuperAdmin as

a UI convenience only. auth.ts blocks suspended users at login with a clear message.

- Admin console (/admin): full-width desktop layout with a persistent left sidebar (Dashboard, Users, Admin Management, Audit, Backups) that collapses to a slide-over on small screens, plus an “Exit to app” control. Reached from a new top-right “Admin” button on the home header (shown only to admins) and the existing Settings entry. The old MobileFrame-wrapped admin-screen.tsx was removed.
- Dashboard: overview cards (users, documents, folders, storage used) and a security widget (locked, suspended, failed logins, deleted), all driven by a date filter (Today / 7 days / 30 days / All time / custom calendar range). Cards drill down into a pre-filtered Users view. Includes a top-users-by-storage list. Backed by GET /api/admin/stats.
- Users: searchable, sortable, paginated account list with status filter (all/admins/locked/suspended/deleted) and filter-aware CSV export. A per-row “View” button opens a user drawer (summary, recent activity) with security actions: adjust storage limit, unlock, suspend/reinstate, and send a password reset link. Super admins cannot be suspended; an admin cannot suspend their own account. Backed by GET /api/admin/users and GET/PATCH /api/admin/users/[id].
- Admin Management (super admin only, hidden otherwise): lists current admins/super admins and a “Create admin” dialog that searches the full user list to promote to Admin or Super Admin, or downgrade. The last remaining super admin cannot be removed. Role changes are super-admin-gated server-side.
- Audit: full log with action filter, free-text search (detail or user email) and date range, plus CSV export (up to 5000 rows). New audit action admin.password_reset_sent recorded when an admin sends a reset link. Backed by GET /api/admin/audit.
- Backups: informational page only (no in-app backup engine) covering platform-managed database snapshots, durable US cloud storage with time-limited signed links, and how to restore a snapshot; notes encryption at rest is a later-phase item and not yet enabled.
- Verified: tsc clean; production build success (all routes, 14 pages, /admin at 31.5 kB); automated auth smoke test passing (signup 201, login 200, session present, suspended login still gated). Browser-verified as the super admin: Admin toggle button, full-screen console, all five sidebar sections, dashboard cards and security widget, users list and user drawer, Admin Management with the Create admin search, audit list and backups page all render and function. Exit-to-app returns to /home.
- IMPORTANT: requires a MANUAL redeploy to lockondocs.abacusai.app AND securevault.dowmandigitalservices.com to go live (manual deploy only per project rules). The schema change and super-admin seed are already applied to the shared database, so

the console and roles take effect on the live hosts only after redeploy of the code.

2026-08-04 | Build 13 | Human-readable data export + branded download links

- Context: two client requests. (1) The “Download my data” export was raw JSON that non-technical users found hard to read, and the document links inside it pointed at the underlying storage host rather than a branded URL. (2) A Settings wording tweak.
- Data export (/api/user/export): now returns a self-contained, styled HTML report instead of JSON. It opens in any browser and shows a branded LockonDocs header, an Account summary (name, email, verification, member since, storage used of limit), summary counts, and each folder with its documents in a table (document name, friendly type label, size, date added, and a Download link). Documents with no folder are grouped under “Other”. The downloaded file is now lockondocs-export-.html.
- Branded download route (/api/files/[id], new): session-gated and scoped by user ID (401 when signed out, 404 for a document the user does not own). It fetches the file from storage server-side and streams it back through the app’s own domain with an attachment filename and the correct extension, so the storage host is never exposed to the user. Export links are built from the incoming request host, so on securevault.dowmandigitalservices.com they are fully branded.
- Settings wording: the security note now reads “Your documents are private and stored securely. Only you can view them.” (dropped the “on US-based infrastructure” phrase).
- Verified: tsc clean; production build success (all routes incl. the new /api/files/[id]); automated auth smoke test passing (signup 201, login 200, session present). Manually verified: the export returns text/html with an .html attachment name and contains no storage-host references; the rendered report is clean and branded; /api/files/[id] returns 401 when unauthenticated and 404 for a non-owned id (per-user isolation holds).
- IMPORTANT: requires a MANUAL redeploy to lockondocs.abacusai.app AND securevault.dowmandigitalservices.com to go live (manual deploy only per project rules). No schema change in this build.

2026-08-04 | Build 14 | Scanner three-way input, centred home header, “Folders” renamed to “Vaults”

- Context: three client requests from Tracey. (1) “Scan a Document” should offer three ways to add content, not just the camera. (2) The home header should show the LockonDocs name larger and centred,

with a larger logo icon centred above it. (3) The word “Folders” should read “Vaults” across the whole app.

- Scanner (components/scanner/scanner-screen.tsx): Add a document now opens on a chooser with three options - “Scan with camera”, “Upload a file” and “Choose from gallery”. The camera no longer auto-starts; it starts only when the user chooses it. Upload a file accepts a PDF or an image: images go through the normal edit/imaging flow, a PDF skips the imaging tools and is shown as a “PDF ready to save” review then uploaded as-is (no re-encoding). Choose from gallery accepts a device-gallery image into the edit flow. Two hidden file inputs are used (gallery: image only; upload: PDF or image). The camera view gained a gallery shortcut and a close-to-chooser control; the no-camera fallback gained a back-to-chooser control. Existing imaging (rotate, crop, brightness/contrast, multi-page, jsPDF export) and the presigned-URL upload path are unchanged.
- Home header (components/home/home-screen.tsx): the logo icon is enlarged and centred at the top with the “LockonDocs” name enlarged and centred directly below it. The admin button (admins only) moved to the top-right corner and still opens /admin.
- Terminology (Folders to Vaults): every user-facing occurrence of “folder”/“folders” now reads “vault”/“vaults” - home screen (headings, buttons, dialogs, toasts, empty state), bottom navigation, search, settings stat, document screen (move-to menu/dialog and back link), the folder screen (titles, dialogs, toasts, alerts), admin console (dashboard card, user drawer, backups copy, CSV header, audit action labels) and all user-facing API error and audit-detail strings.
- Deliberately kept internal for stability (NOT user-visible): the database model name (Folder), the /api/folders routes, the /folder/[id] URL path, all variable/type/prop names, the built-in icon value “folder”, lucide icon component names, function names, html id/for attributes, and audit action keys (e.g. folder.update). Only the friendly labels shown for those audit keys were renamed. Rationale: a surgical, display-only rename avoids route/schema regressions; the URL is not visible inside the GoodBarber iframe.
- Verified: tsc clean; production build success (all routes, 14 pages; /scan at 141 kB); automated auth smoke test passing (signup 201, login 200, session present). This is a UI/feature change, so no browser walkthrough was required beyond the automated checks.
- IMPORTANT: requires a MANUAL redeploy to lockondocs.abacusai.app AND securevault.dowmandigitalservices.com to go live (manual deploy only per project rules). No schema change in this build.

2026-08-04 | Build 15 | Cross-platform (iOS/Android) upload flow for gallery and file import

- Context: follow-up on the Build 14 upload options. Choosing “Upload a file” or “Choose from gallery” behaves differently on iOS and Android, and the flow needed to be reliable on both.
- HEIC/HEIF photos (iOS): iPhones save photos as HEIC by default, which browsers cannot decode on a canvas and which Android/desktop cannot display. A selected HEIC/HEIF file is now converted to JPEG in the browser using `heic2any` (dynamically imported so the decoder only loads when needed) before it enters the edit flow. Everything downstream is unchanged.
- Type detection: files are now classified by BOTH the reported MIME type and the filename extension. Android file managers and content-URI pickers frequently report an empty or generic MIME type, which previously could reject a valid image or a PDF. The gallery input accepts `image/`, `.heic`, `.heif` and the upload input accepts `application/pdf`, `image/`, `.pdf`, `.heic`, `.heif` so those files stay selectable even when the MIME type is missing.
- Feedback: a “Preparing your photo” overlay is shown while a large photo is decoded/converted, so the screen is never a dead tap on either platform.
- Dependency added: `heic2any` (client-only, dynamically imported).
- Verified: tsc clean; production build success (all routes; /scan now 141 kB with the decoder loaded on demand); automated auth smoke test passing (signup 201, login 200, session present). Behaviour that depends on a physical iPhone/Android photo picker (the OS file/photo sheet, real HEIC capture) can only be fully confirmed on-device after deploy.
- IMPORTANT: requires a MANUAL redeploy to `lockondocs.abacusai.app` AND `securevault.dowmandigitalservices.com` to go live (manual deploy only per project rules). No schema change in this build.

2026-08-05 | Build 16 | Metallic “proper gold” design upgrade

- Context: Tracey noted the gold used across the app looked like a single flat mono colour, unlike the logo which reads as polished gold reflecting the light. Request was to upgrade the look so the app feels like a proper gold design.
- New reusable CSS utilities (`app/globals.css`, in `@layer` utilities):
 - “`.gold-surface`” gives a diagonal multi-stop gold gradient (light-to-mid-to-deep-to-light) with a top-left light sheen and a soft inner shadow via a `::before` pseudo, so surfaces read as polished metal rather than a flat fill.
 - “`.gold-shimmer`” adds a slow light-sweep highlight (`::after`) for hero surfaces.
 - “`.gold-tile`” is a softer, paler polished-gold gradient for

the small icon backgrounds. The sheen/shimmer sit on negative-z pseudos with isolation so they stay above the fill but below the text/icons, keeping dark text fully legible; a prefers-reduced-motion guard disables the sweep for users who ask for less motion.

- Where applied: the primary Button “default” variant (covers Sign in and other primary buttons app-wide), the home “Scan a document” hero button and the bottom-nav floating scan button (both with the shimmer sweep), the home vault and recent-document icon tiles, the folder/document/search icon tiles, the selected folder-icon chips (home create dialog and folder rename), the admin nav active tab, the scanner “Scan with camera” icon circle, and the settings profile avatar circle. Semantic UI primitives (checkbox, slider, switch, progress, calendar, toasts) were deliberately left on the flat token so state indication stays clear.
- No colour tokens were changed; the existing -primary gold and -accent-foreground bronze drive the gradients, so the palette is unchanged and only the finish is richer.
- Verified: tsc clean; production build success (all 14 routes); automated auth smoke test passing (signup 201, login 200, session present). Manually verified in the browser (light theme, logged in as a test account): the Sign in button, hero scan button, floating scan button and vault tiles all render as polished light-reflecting gold with the sheen, and dark text stays legible.
- IMPORTANT: requires a MANUAL redeploy to lockondocs.abacusai.app AND securevault.dowmandigitalservices.com to go live (manual deploy only per project rules). No schema change in this build.
- Follow-up fix (same build): the bottom-nav floating scan button briefly lost its centred placement because “.gold-surface” sets position: relative, which overrode the button’s “absolute” positioning. Fixed by forcing the button back to absolute (Tailwind !absolute) so it stays centred and raised above the bar. Re-verified in the browser: the gold scan button sits centred in the bottom bar with its ring and metallic finish.

2026-08-05 | Build 17 | Streamlined home, native-picker Upload nav shortcut, new Activity screen

- Context: Tracey tested the latest build on Android and reported the add-a-document flow felt clunky (too many taps) and that the native picker was inconsistent - “Upload a file” and “Choose from gallery” opened different app choices (Camera / Camera Camcorder / Files versus Camera / MyFiles / Files), which was confusing. She asked to

simplify the home screen and rebalance the bottom bar with two new shortcuts.

- Home screen (components/home/home-screen.tsx): removed the large gold “Scan a document” hero bar (the floating gold scan button already makes that action obvious) and removed the “Scan a new document or open a vault to get started” description line. The old two-line greeting (small “Welcome back,” over a large name heading) is replaced by a single small, centred, normal-weight line “Welcome back, {name}”. The logo and LockonDocs wordmark are unchanged.
- Bottom navigation (components/app/bottom-nav.tsx): expanded from two items to four plus the centre scan button, laid out as Vaults | Upload | (gold scan button) | Activity | Settings. This visually balances the bar (two items each side of the centre button). Item labels and paddings were tightened so four labels fit the mobile width. The centre scan button keeps its metallic finish and forced absolute centring.
- Upload shortcut: the new Upload nav item opens the scanner at /scan?pick=upload, which auto-opens the phone’s native file/photo picker in a single tap (runs once on mount; if the user cancels they land on the normal chooser). This removes taps from the common “add an existing file” path.
- Consistent picker (fixes the Android complaint): the scanner chooser (components/scanner/scanner-screen.tsx) now offers just two options - “Scan with camera” and “Upload a file or photo” (one unified input that accepts PDF or image, from files or gallery). Collapsing the separate “Upload a file” and “Choose from gallery” options into one means the device now shows a single, consistent native picker instead of two different ones. The in-camera gallery shortcut and the existing HEIC-convert / imaging / presigned-upload pipeline are unchanged.
- New Activity screen (app/activity/page.tsx, components/activity/activity-screen.tsx): a lightweight personal stats view for the signed-in user - three cards (Vaults, Documents, Storage used of limit), a storage-usage bar, and a “Recent activity” feed of the user’s own audit entries (up to 30, newest first) with friendly action labels and timestamps. Backed by a new session-gated API (app/api/user/activity/route.ts) that returns only the current user’s audit rows (strict per-user scoping; 401 if not signed in). Reuses the existing shared formatting helpers. No schema change.
- Verified: tsc clean; production build success (all routes incl. /activity and /api/user/activity); automated auth smoke test passing (signup 201, login 200, session present). Manually verified in the browser (logged in as a test account): streamlined home header, balanced five-slot bottom bar, the Upload shortcut opening the native picker in one tap with the two-option chooser behind it, and the Activity screen showing correct per-user stats and the recent-login feed.

- **IMPORTANT:** requires a **MANUAL** redeploy to lockondocs.abacusai.app AND securevault.dowmandigitalservices.com to go live (manual deploy only per project rules). No schema change in this build.

2026-08-05 | Build 18 | In-app document preview and branded download source

- **Context:** Tracey tested the add-a-document flow on Android (uploaded a PDF). The flow worked and the item appeared in her vault, but two things fell short. (1) Opening the document did not show a real visual preview of what she uploaded - she wanted to actually see the document, and any image should render properly and never be squashed (for example a landscape photo). (2) The device "Download file?" dialog showed the raw storage source (an amazonaws.com host) instead of our own branded domain.
- **Branded streaming route** (app/api/files/[id]/route.ts): the existing per-user, session-gated file route now supports a "disposition" query param. "?disposition=inline" streams the file for in-app viewing (Content-Disposition: inline); with no param it stays a proper download (Content-Disposition: attachment) with the correct filename and extension. Either way the bytes are streamed through the app's own domain, so the underlying storage host is never shown to the user. Strict per-user scoping (userId on the query, 401 if not signed in) is unchanged.
- **Document view** (components/document/document-screen.tsx): a PDF now renders inline in an embedded viewer (an iframe pointed at the branded inline route) instead of a generic PDF icon, so the user sees the actual document. An image renders through the same branded inline route with object-contain and h-auto, so the whole image is visible at its true aspect ratio and a landscape scan is never squashed (it is letterboxed against the muted panel rather than stretched or cropped). The Download button now points at the branded route (/api/files/[id]) rather than the raw signed storage URL, which is what fixes the download-source complaint.
- **Vault grid thumbnails** (components/folder/folder-screen.tsx): image tiles now load through the branded inline route as well, so no storage host is exposed anywhere in the UI. PDF tiles keep the clean labelled "PDF" placeholder in the grid (a true first-page PDF thumbnail would need a heavy PDF-rendering library that is unreliable inside the iOS in-app browser); the real PDF preview is on the document view when the tile is tapped.
- **Verified:** tsc clean; production build success (all 15 routes, /api/files/[id] included). Manually verified in the browser signed in as a test account: uploaded a PDF and a 1200x500 landscape image into a vault, confirmed the PDF renders inline in the viewer and the

landscape image shows in full without being squashed, and confirmed via a fetch that the download response comes from the app's own domain with Content-Disposition attachment and does not expose the amazonaws.com host. The two test documents were deleted afterwards so the shared database is left clean.

- **IMPORTANT:** requires a **MANUAL** redeploy to lockondocs.abacusai.app AND securevault.dowmandigitalservices.com to go live (manual deploy only per project rules). No schema change in this build.

2026-08-06 | Build 19 | Direct camera/upload entry points and tightened GoodBarber back navigation

- Context: two follow-ups from Tracey after testing on Android. (1) Back-button: from the GoodBarber app, tapping the landing "Access My Vault" opened the vault fine, but the first back press only reloaded the page and a second press was needed to return to the GoodBarber app. (2) The Upload shortcut still routed through the "Scan with camera / Upload a file or photo" chooser screen and, on the FAB, the extra chooser screen showed before the camera. Tracey asked that Upload go straight to gallery/files (NO camera) and the centre FAB go straight to the camera, both with no intermediate screen.
- Back navigation (app/page.tsx, components/auth/login-form.tsx): the landing "Access My Vault" launch now opens the final destination (/home) first-party in the top-level context instead of /login. Previously opening /login while already signed in caused a server redirect to /home, adding an extra history entry, and the login form then used window.location.assign which added another - so the vault sat two hops deep and needed two back presses. The launch now targets /home directly, and after a fresh sign-in the login form uses window.location.replace("/home") instead of assign, so the /login page is not left in history. The window.open(_blank) break-out of the GoodBarber embed (needed for first-party cookies/login/camera) is unchanged. Net effect: the vault is a single history hop from the GoodBarber shell, so one back press returns to the app.
- Direct entry points (components/app/bottom-nav.tsx, components/scanner/scanner-screen.tsx): the centre FAB now routes to /scan?pick=camera and the scanner opens straight into the camera (loading -> camera) with no chooser screen. The Upload nav item routes to /scan?pick=upload and the scanner opens on a new minimal "Upload a document" screen that immediately triggers the native file/photo picker and offers a single "Choose from gallery or files" button plus Cancel - NO camera option anywhere on that path. If the user cancels the picker they remain on the minimal upload screen (not the two-option chooser). The scanner Stage type gained an "upload" state and the initial stage is derived from the pick param; the auto-pick effect starts the camera for pick=camera and opens the file

picker for pick=upload (guarded to run once). The in-vault “Scan into this vault” action (/scan with no pick param) deliberately still shows the two-option chooser so that in-vault add keeps both camera and upload choices.

- Note on the Android system picker: the OS file chooser that lists Camera / Camcorder / Files is the Android IntentResolver, shown by the operating system because the file input accepts images. That system sheet’s contents are controlled by Android and cannot be forced from a web app, so the “Camera” entry may still appear in the OS sheet on some devices. What this build guarantees from the app side is that Upload never shows the in-app camera flow or the extra chooser screen, and the FAB is camera-only. The upload input accept list (PDF or image, from files or gallery) is unchanged so gallery photos stay selectable.
- Verified: tsc clean; production build success (all 15 routes; /scan 141 kB). Manually verified in the browser signed in as a test account: the Upload nav opens the native file picker in one tap with the new minimal camera-free upload screen behind it, and the FAB goes straight to the camera attempt (the VM has no camera so it correctly lands on the camera-unavailable fallback) with no chooser screen flashing in between. The back-button behaviour inside the GoodBarber shell and the exact contents of the Android system picker can only be confirmed on-device after deploy, as neither the GoodBarber embed nor a physical Android picker can be reproduced in the build environment. No test documents were created.
- IMPORTANT: requires a MANUAL redeploy to lockondocs.abacusai.app AND securevault.dowmandigitalservices.com to go live (manual deploy only per project rules). No schema change in this build.
- Follow-up fix (same build, 2026-08-06): Tracey reported the Upload path’s single native picker only offered “Files” and not the photo gallery, so choosing a photo meant hunting through the file browser. Root cause: a single file input whose accept list mixes PDFs and images makes Android open the document/Files browser, which hides the gallery. Fixed by making the Upload screen (components/scanner/scanner-screen.tsx) present two explicit options instead of auto-opening one combined picker: “Photo gallery” triggers an image-only input (accept image/*,.heic,.heif) so Android surfaces the photo gallery, and “Files” triggers the PDF/file input for documents. The pick=upload entry no longer auto-opens a picker; it lands on this two-option screen so the gallery is always reachable in one tap. The FAB camera-only path and the in-vault two-option chooser are unchanged. Re-verified in the browser: the Upload screen shows Photo gallery and Files (no camera), and Photo gallery fires the

image-only input. The exact device gallery UI can only be confirmed on-device after deploy.

- Follow-up fix 2 (same build, 2026-08-06): Tracey reported three things still wrong after the previous follow-up. (1) Camera mode showed two close controls, an X top left and a second X bottom right, and the bottom-right one went back to the in-app chooser instead of closing. (2) Tapping Upload still landed on an in-app “Photo gallery / Files” page, and neither option produced a gallery on Android web. (3) Coming from GoodBarber into the vault still needed two back presses.
 - Camera close (components/scanner/scanner-screen.tsx): the second, bottom-right X was removed entirely and replaced with an invisible spacer so the capture button stays centred. The camera view now has exactly three controls: Close scanner (top left), Choose from gallery (bottom left) and Capture (centre). Close performs a single-step exit (stop the camera stream, then router.replace to /home).
 - Upload with no in-app screen (components/app/bottom-nav.tsx, new lib/pending-upload.ts, components/scanner/scanner-screen.tsx): the in-app “Photo gallery / Files” screen was deleted, along with the scanner’s “upload” stage. The Upload nav item now owns a hidden file input and clicking it opens the phone’s native picker directly, on top of the vaults screen, with no navigation at all. Cancelling the picker leaves the user exactly where they were. Choosing a photo parks the File in a small in-memory handoff module (lib/pending-upload.ts, single slot, cleared on read, because a File cannot be passed in a URL) and routes to /scan?pick=pending, which picks the file straight up and goes to the review and edit screen.
 - Why the gallery was missing on Android: Chrome and Samsung Internet map the accept list onto an Android intent. Android’s photo gallery picker is only used when the accept list is image types only. As soon as the list contains a non-image type such as application/pdf, or a bare file extension the system cannot resolve to a MIME type (.heic and .heif are the usual offenders), the browser falls back to the generic Camera / Camcorder / Files chooser, which has no gallery. Build 15 added those extensions for file-manager compatibility and that is what hid the gallery. The Upload path now uses a plain accept=“image/*” with no extensions and no PDF, and the in-camera gallery shortcut was cleaned the same way. HEIC photos still work: the OS reports them as an image type, and the existing HEIC conversion runs after selection because file-type detection checks both MIME type and extension.

- Trade-off to be aware of: the Upload icon is now images only. Adding PDFs back to that accept list would re-trigger the generic file browser and hide the gallery again. PDFs are still uploadable from inside a vault via “Scan into this vault”, which keeps the two-option chooser and its combined PDF or image input. A separate Files entry can be added to the bottom bar if Tracey wants PDFs from the bottom bar too.
- Back navigation (components/home/vault-launch.tsx, components/auth/register-form.tsx, components/settings/settings-screen.tsx): every remaining history push on the shell-to-vault path was converted to a history replace. The vault-launch fallbacks used when a webview ignores target=_blank now call location.replace instead of assigning location.href, so the landing page is not left sitting behind the vault. Registration now replaces rather than assigns on both its exits, so /register is not left in history for a new user coming in from the shell. Account deletion also replaces, so a back press cannot return to a deleted account’s screens. The window.open(_blank) first-party break-out is unchanged.
- Verified in the browser signed in as a test account: tapping Upload opens the operating system picker immediately with the vaults screen still behind it and the filter set to images only; cancelling returns to the vaults screen with nothing changed; picking a real photo goes straight to the review and edit screen with no intermediate page; the FAB goes straight to the camera attempt with no chooser; the camera view exposes exactly one close control and it returns to the vaults in a single tap (confirmed by rendering the camera stage against a synthetic video stream, since the build environment has no camera). tsc clean and production build success (all 15 routes). No test documents were created, and 22 leftover automated smoke-test accounts were removed from the shared database.
- Still needs on-device confirmation after deploy: the actual contents of the Android system picker, and the GoodBarber back-button behaviour. Neither a physical Android picker nor the GoodBarber shell can be reproduced in the build environment.